UNIVERSIDAD PRIVADA DE TACNA

Facultad de Ingeniería
Escuela de Ingeniería de Sistemas

Plan de auditoría de seguridad del canal digital

Clínica Santa Lucía S.A.C.

SI-084 · Auditoría de Sistemas
Examen práctico de Unidad II

Apellidos y nombres: Chire Ramos, Mayra Fernanda

Código de estudiante: 2021072620

Docente: Dr. Oscar Juan Jimenez Flores

URL del repositorio: https://github.com/mayrafc/si084-caso-clinica/tree/examen-u2

Fecha: 28/10/2026 · Tacna, Perú

Periodo auditado: 01/01/2026 al 30/09/2026

Tacna, Perú · 2026

CONFIDENCIAL · USO ACADÉMICO

1. Resultados del reconocimiento OWASP WSTG 4.2

El reconocimiento sustenta la planificación; no demuestra explotación ni funcionamiento histórico de los controles. Las pruebas de la sección 6 se proponen para Unidad III y requieren aprobación y autorización técnica específica.

E1 Aplicaciones · WSTG-INFO-04

Respondieron **3 de 11 puertos**: 8080, portal; 8081, pruebas; 8088, API de citas 1.4.0; todos HTTP 200. Pruebas anuncia copia de producción restaurada el **12/09/2026** y el usuario admin_pruebas. La API declara entorno **produccion** y tres endpoints, que no se consultaron. **D1 no coincide:** declara un activo, se encontraron tres. La copia productiva es una declaración publicada, no una base de datos inspeccionada.

Evidencia: evidencias/E1_aplicaciones.txt.

E2 Servidor y lenguaje · WSTG-INFO-02

Cabeceras: **nginx/1.20.2** y **PHP/7.4.3**. PHP 7.4 terminó soporte el **28/11/2022** [F1]. Nginx clasifica 1.20 como rama heredada [F2]; 1.22 la sustituyó como estable el **24/05/2022** [F3]. Esta última es fecha de sustitución, no un anuncio oficial de EOL, cuya fecha exacta no quedó acreditada. **D2 no coincide:** PHP está fuera de soporte y nginx es heredado. Son huellas del simulador; no prueban que PHP esté instalado.

Evidencia: evidencias/E2_servidor.txt y evidencias/FUENTES.txt.

E3 Metarchivos · WSTG-INFO-03

Hay **4 Disallow**: /admin/, /respaldos/, /resultados/ y /wp-content/plugins/wp-file-manager/. Robots publica además un sitemap. Security.txt devuelve **404**. Disallow revela rutas y no controla acceso. **Sin declaración D específica**, no procede marcar coincidencia. No se visitó el dominio .test anunciado.

Evidencia: evidencias/E3_metarchivos.txt.

E4 Contenido · WSTG-INFO-05

Se observaron **4 comentarios**: proveedor/contacto; usuario admin_pruebas; integración interna http://10.20.0.15:8090/lis/resultados; patrón ver.php?orden=NNNNN. Tres revelan cuenta, arquitectura o direccionamiento de resultados; el cuarto identifica al proveedor. La contraseña inicial anunciada es **fecha de nacimiento ddmmaaaa**, ocho dígitos. Generator anuncia WordPress 5.8.1. **D8 no coincide:** sí existen comentarios y datos internos. No se usaron la cuenta, la dirección ni el patrón.

Evidencia: evidencias/E4_contenido.txt.

E5 Componentes · WSTG-INFO-08

Hay **4 referencias versionadas**: MedicalPro 2.1.0, Contact Form 7 5.3.1, jQuery 3.4.1 y WP File Manager con ver=6.8. WordPress anuncia **5.8.1**, frente a 6.6 declarado. **D3 no coincide con la actualización declarada**; una instantánea no demuestra la periodicidad histórica. **CVE-2020-25213** afecta WP File Manager anterior a 6.9 y permite cargar y ejecutar PHP [F4]. La referencia 6.8 motiva revisión; no confirma instalación ni explotabilidad.

Evidencia: evidencias/E5_componentes.txt, E4 y evidencias/FUENTES.txt.

E6 Entradas · WSTG-INFO-06

Hay **4 formularios**: citas, resultados, postula y admin. Tres solicitan datos personales de pacientes/postulantes; admin pide usuario y clave. Citas incluye especialidad y síntomas, datos de salud, y usa **GET**. Postula recibe **un CV**. Los **4 action usan HTTP**; los otros tres métodos son POST. **D7 no coincide con el diseño observado:** citas puede exponer datos en URL y los cuatro flujos apuntan a transporte sin cifrado. No se enviaron datos ni se probó el procesamiento. La solicitud informa aceptación sin texto; la evidencia confirma la casilla, no un consentimiento válido.

Evidencia: evidencias/E6_entradas.txt; contexto en SOLICITUD-DE-AUDITORIA.md.

E7 Expuestos · WSTG-CONF-04 y WSTG-CONF-05

El índice /respaldos/ lista **4 archivos**, sin contar el vínculo padre: **2 .sql.gz**, **1 .csv**, **1 .php.bak**. No se descargaron. /admin/ devuelve **200** desde un cliente ajeno a la red de WebSur. **D5 y D6 no coinciden en el laboratorio:** panel alcanzable y respaldos anunciados dentro de web. No se acreditó acceso administrativo ni contenido de los archivos.

Evidencia: evidencias/E7_expuestos.txt.

E8 Cabeceras y cookie · WSTG-CONF-07, WSTG-CONF-12 y WSTG-SESS-02

Faltan **4/4 cabeceras**: HSTS, CSP, X-Frame-Options y X-Content-Type-Options. PHPSESSID solo declara path=/; faltan **3 atributos**: Secure, HttpOnly y SameSite. **D4 no coincide** con las cabeceras ni con los action HTTP de E6. **HTTPS en 443 no se ejecutó:** el alcance escrito solo autoriza 8080-8090 y 443 pertenece a Greenbone, ajeno al caso. No se inventa HTTP 000. Compose no publica TLS; HTTPS del portal real queda pendiente.

Evidencia: evidencias/E8_cabeceras.txt, evidencias/CONTEXTO-DOCKER.txt y docker-compose.yml.

2. Materia de control

Se auditará la protección de datos personales y de salud del canal digital de Clínica Santa Lucía S.A.C., incluidos portal, pruebas, API y controles de WebSur, del **01/01/2026 al 30/09/2026**. Justifican la auditoría el reclamo del 08/09/2026 por un hemograma ajeno, cerrado sin informe según solicitud, el patrón de órdenes publicado en E4 y la cookie débil de E8. E1 amplía la materia a un entorno que anuncia copia de producción y no fue declarado.

3. Alcance

Incluye

Portal http://127.0.0.1:8080/. Un portal; inicio, metarchivos, componentes y configuración. Dominio declarado portal.clinica-santalucia.test, sin visitarlo.

Citas :8080/citas/. 3 850 citas/mes. 34 650 en nueve meses es proyección, no conteo; solicitar universo real enero-setiembre.

Resultados :8080/resultados/. 12 400 pacientes con cuenta; solicitar total de órdenes y accesos del periodo. Incluir incidente 08/09/2026.

Postula :8080/postula/. 214 postulaciones con CV en 2026; determinar cuáles corresponden hasta 30/09.

Administración :8080/admin/. Un panel; universo de cuentas, roles y accesos por solicitar.

Respaldos :8080/respaldos/. Cuatro nombres listados. Los de 2025 quedan incluidos por exposición observada; no se presupone contenido.

Pruebas http://127.0.0.1:8081/. Un entorno; copia declarada 12/09/2026. Titulares, filas, usuarios y anonimización por confirmar.

API http://127.0.0.1:8088/. Una API y tres endpoints anunciados: citas, pacientes y resultados. Poblaciones vinculadas a las anteriores, sin duplicar titulares; operaciones por solicitar.

WebSur e integración LIS referenciada. Un proveedor y una integración anunciada. Contrato, responsabilidades, cambios e incidentes; sin acceso técnico al LIS.

Periodo auditado

01/01/2026 a 30/09/2026. El reconocimiento del 28/10 es posterior y no acredita configuraciones históricas; contrastar con logs, cambios y respaldos de configuración entregados formalmente.

Exclusiones expresas

Excluir auditoría financiera, juicio clínico, seguridad física y sistemas internos fuera del canal. No acceder a 10.20.0.15, al dominio .test ni a servicios ajenos. El reconocimiento excluye formularios enviados, contraseñas probadas, descarga de respaldos, endpoints /v1/, fuzzing y escaneo activo por prohibición del alcance firmado. Las pruebas posteriores requieren nueva autorización y réplica sintética.

Limitaciones inherentes

Simulación con páginas estáticas y cabeceras declaradas, sin comprobación de bases ni controles operativos. Faltan logs, contrato completo, inventarios y expediente de incidente. Las cuentas no equivalen a órdenes; el volumen anual de CV no equivale al periodo de nueve meses. El puerto 443 está fuera de alcance y ocupado por otro laboratorio. Las muestras dirigidas no permiten extrapolación estadística ni asegurar ausencia total de fallos.

4. Objetivos

General: determinar si los controles del canal digital protegen confidencialidad, integridad y disponibilidad de datos de salud y personales en el periodo. **Pregunta:** ¿protege el canal digital los datos de salud de los pacientes?

N.º: OE1 **Objetivo específico:** Determinar si autenticación, autorización y sesión impiden consulta cruzada y permiten esclarecer el incidente. **Pregunta de auditoría:** ¿Cada paciente accede solo a sus resultados con sesión válida y sin mezcla de caché?

N.º: OE2 **Objetivo específico:** Determinar si cifrado, configuración y mantenimiento protegen todos los activos descubiertos. **Pregunta de auditoría:** ¿Se cifran comunicaciones y se restringen panel, respaldos, pruebas y componentes inseguros?

N.º: OE3 **Objetivo específico:** Determinar si captura y tratamiento de datos y CV cumplen finalidad, seguridad y base legal. **Pregunta de auditoría:** ¿Se recopilan datos por medios seguros, con información al titular y consentimiento o excepción sustentada?

5. Enfoque, materialidad y riesgo

Elemento: Enfoque **Decisión:** Sustantivo basado en riesgos, con evaluación de diseño **Sustento:** E1 contradice inventario; E6-E8 muestran exposición. No hay fundamento para confiar sin corroboración en WebSur.

Elemento: Materialidad cuantitativa **Decisión:** Tolerancia cero a un resultado ajeno, respaldo sensible público o credencial en URL **Sustento:** Un caso confirmado es material. Dimensionar con 12 400 cuentas, 3 850 citas/mes y 214 postulaciones anuales; no usar ingresos de S/18 600 000 como umbral de privacidad. Muestras por procedimiento.

Elemento: Materialidad cualitativa **Decisión:** Toda divulgación de salud, copia productiva sin protección o tratamiento sin base legal es relevante **Sustento:** Incidente, E1/E4/E6/E7. Salud es dato sensible, Ley 29733 art. 2.5.

Elemento: Riesgo inherente **Decisión:** Alto **Sustento:** Datos de salud, volumen de cuentas, incidente y patrón de orden E4.

Elemento: Riesgo de control **Decisión:** Alto, preliminar **Sustento:** E1/E2/E5 discrepan del proveedor; E7/E8 muestran barreras ausentes. Operación histórica pendiente.

Elemento: Riesgo de detección **Decisión:** Bajo como objetivo; actualmente alto por limitaciones **Sustento:** Reducir mediante pares sintéticos, censo de configuraciones y triangulación de logs/cambios/entrevista. Reconocimiento pasivo no basta para declararlo bajo.

6. Procedimientos

Ejecutar en **Unidad III**, tras aprobación escrita con sistemas, cuentas, rutas, acciones y ventana autorizados. Usar réplica aislada y datos sintéticos; registrar permisos o universos faltantes como limitación. Cubren seis categorías WSTG: ATHZ, ATHN, SESS, CRYP, CONF y BUSL.

P-01 Autorización e incidente de setiembre

Objetivo específico. OE1

Origen. E4: patrón orden; E1: API de resultados; solicitud: hemograma ajeno el 08/09/2026.

Riesgo. Acceso horizontal a resultados o caché mezclada entre titulares.

Criterio. WSTG-ATHZ-04; ASVS 4.0.3 V4.2.1 y V8.1.1; NTP-ISO/IEC 27001:2022 A.8.3 y A.5.26; Ley 29733 arts. 9 y 17.

Tipo de prueba. Sustantiva de autorización y examen documental del incidente.

Población y muestra. 12 400 cuentas; órdenes/accesos por obtener. Censo del reclamo y sus registros conservados; 10 pares sintéticos A/B con órdenes distintas por canal autorizado.

Procedimiento. 1. Solicite reclamo, ticket, logs del 08/09, cambios y configuración de caché. 2. Reconstruya cronología sin copiar hemogramas reales. 3. Prepare 10 pares A/B en réplica. 4. Consulte orden propia como control positivo. 5. Sustituya solo ID de orden por el de B y repita como A, B y anónimo. 6. Alterne titulares por la caché; revise autorización de servidor y claves de caché. 7. Compare logs/respuestas con la explicación de WebSur y documente faltantes.

Evidencia a obtener. Cronología disociada, matriz por par/canal, respuestas sintéticas, configuración y logs redactados.

Excepción definida. Una respuesta entrega orden ajena o datos a un anónimo, o caché mezcla titulares. Cierre sin causa, contención y verificación trazables es excepción documental separada; falta de logs no prueba IDOR.

Horas. 6

P-02 Autenticación y alta

Objetivo específico. OE1

Origen. E4: fecha de nacimiento como clave inicial y cuenta de pruebas; E6: formularios de acceso.

Riesgo. Suplantación por secreto predecible o cuenta de prueba activa.

Criterio. WSTG-ATHN-02 y WSTG-ATHN-07; ASVS 4.0.3 V2.1.1 y V2.3.1; NTP-ISO/IEC 27001:2022 A.5.17 y A.8.5; Ley 29733 art. 9.

Tipo de prueba. Sustantiva de autenticación y revisión de aprovisionamiento.

Población y muestra. 12 400 cuentas; censo documental de cuentas privilegiadas/de prueba por solicitar; 10 altas sintéticas.

Procedimiento. 1. Obtenga política y flujo de alta/recuperación. 2. Concilie estado y permisos de cuentas de prueba. 3. Prepare 10 altas sintéticas y documente entrega y caducidad del secreto. 4. Compruebe si fecha de nacimiento da acceso clínico antes de fijar secreto propio. 5. Verifique cambio inicial y caducidad de códigos en los límites aprobados. 6. Use solo credenciales sintéticas; revise admin_pruebas por inventario, sin adivinar claves.

Evidencia a obtener. Política, flujo, inventario disociado y matriz de altas con secretos ocultos.

Excepción definida. Un alta accede a datos clínicos con fecha de nacimiento; contraseña elegida menor de 12 caracteres aceptada; código inicial sin caducidad o sin cambio requerido; cuenta de prueba con privilegios productivos sin justificación aprobada.

Horas. 4

P-03 Sesión

Objetivo específico. OE1

Origen. E8: cookie sin Secure, HttpOnly ni SameSite.

Riesgo. Robo o reutilización de sesión en equipos compartidos.

Criterio. WSTG-SESS-02 y WSTG-SESS-06; ASVS 4.0.3 V3.4.1, V3.4.2, V3.4.3 y V3.3.1; NTP-ISO/IEC 27001:2022 A.8.5 y A.8.26; Ley 29733 art. 9.

Tipo de prueba. Sustantiva de atributos e invalidación.

Población y muestra. Censo de cookies/mecanismos de las tres aplicaciones; cinco ciclos sintéticos de inicio/cierre por mecanismo encontrado.

Procedimiento. 1. Enumere mecanismos con Sistemas. 2. Capture Set-Cookie antes y después del acceso en réplica. 3. Verifique tres atributos, dominio y ruta. 4. Cierre sesión y reintente recurso propio con el token anterior. 5. Repita cinco ciclos por mecanismo. 6. Contraste invalidación en servidor con logs; para mecanismos sin cookie documente no aplicabilidad de atributos y pruebe revocación.

Evidencia a obtener. Cabeceras redactadas, tabla de atributos y respuestas/logs tras cierre.

Excepción definida. Una cookie de sesión carece de cualquiera de los tres atributos o un token cerrado conserva acceso protegido.

Horas. 3

P-04 Cifrado y datos en tránsito

Objetivo específico. OE2 y OE3

Origen. E6: cuatro action HTTP y citas GET; E8: HSTS ausente y HTTPS pendiente.

Riesgo. Intercepción de datos/credenciales y permanencia de información sensible en URLs.

Criterio. WSTG-CRYP-03 y WSTG-CONF-07; ASVS 4.0.3 V9.1.1, V8.3.1 y V14.4.5; NTP-ISO/IEC 27001:2022 A.8.24 y A.8.20; Ley 29733 arts. 9 y 16.

Tipo de prueba. Sustantiva de transporte y examen de configuración.

Población y muestra. Censo de tres aplicaciones, cuatro formularios y tres endpoints anunciados. Punto TLS sujeto a autorización adicional de dirección/puerto.

Procedimiento. 1. Identifique terminación TLS y solicite permiso para sus puertos. 2. Prepare datos ficticios marcados. 3. Capture cada flujo en réplica. 4. Verifique TLS, ausencia de fallback y redirección antes de ingresar datos, y HSTS en HTTPS. 5. Examine URL, historial y logs de prueba buscando DNI, síntomas, claves o tokens. 6. Complete matriz de todos los canales autorizados y registre pendientes.

Evidencia a obtener. Configuración/certificado, matriz de canales, URL y capturas de tráfico sintético.

Excepción definida. Un flujo sensible se transmite por HTTP o query string; HTTPS sin HSTS; o fallback permite datos en claro. TLS no autorizado se registra pendiente, sin inventar fallo.

Horas. 4

P-05 Configuración, activos y mantenimiento

Objetivo específico. OE2

Origen. E1: activos omitidos/copia productiva; E2/E5: versiones; E3: rutas; E7: respaldos/panel; E8: cabeceras.

Riesgo. Exposición masiva o compromiso por componentes vulnerables y entornos sin segregación.

Criterio. WSTG-CONF-02, WSTG-CONF-04 y WSTG-CONF-05; ASVS 4.0.3 V14.2.1, V14.1.3 y V8.1.6; NTP-ISO/IEC 27001:2022 A.8.8, A.8.9, A.8.13 y A.8.31; Ley 29733 arts. 9 y 16.

Tipo de prueba. Examen documental y sustantiva controlada de configuración.

Población y muestra. Censo de tres aplicaciones, un panel, cuatro nombres de respaldo, cinco componentes web incluido WordPress y dos tecnologías de cabecera. Seleccione nueve cierres mensuales de parcheo enero-setiembre si existen.

Procedimiento. 1. Concilie inventario y responsables con D1-D8. 2. Solicite configuraciones, SBOM, permisos y registros de cambios. 3. Confirme versiones instaladas y aplicabilidad de CVE-2020-25213 sin explotarla. 4. Revise segregación, anonimización de pruebas, panel y almacenamiento de respaldos. 5. En réplica cree un archivo señuelo inerte y compruebe bloqueo de índice y contenido desde perfil externo; no descargue originales. 6. Verifique CSP, nosniff y protección de enmarcado en las tres aplicaciones. 7. Contraste contrato y responsables de parches, seguridad y respaldos.

Evidencia a obtener. Inventario/SBOM, matriz CVE, configuraciones redactadas, nueve cierres o faltantes, prueba señuelo y cláusulas de WebSur.

Excepción definida. Señuelo público; panel fuera de red permitida; copia productiva sin anonimización o protección equivalente aprobada; CVE aplicable sin mitigación validada; cabecera requerida ausente; o responsabilidad contractual sin asignar.

Horas. 6

P-06 Formularios, privacidad y CV

Objetivo específico. OE3

Origen. E6: datos personales/salud, campo medico_id y carga CV; solicitud: aceptación sin texto.

Riesgo. Tratamiento sin información/base legal, alteración de reglas y carga insegura.

Criterio. WSTG-BUSL-01 y WSTG-BUSL-08; ASVS 4.0.3 V8.3.3 y V12.1.1; NTP-ISO/IEC 27001:2022 A.5.34 y A.8.26; Ley 29733 arts. 6, 7, 13.5, 13.6, 14 y 18.

Tipo de prueba. Sustantiva de reglas de negocio y revisión de privacidad.

Población y muestra. Censo de tres formularios de pacientes/postulantes. Del universo real enero-setiembre, seleccione 30 citas y 20 postulaciones distribuidas por meses disponibles, o censo si hay menos; use registros disociados. Seis archivos sintéticos.

Procedimiento. 1. Obtenga avisos, finalidades, conservación y base legal por flujo. 2. Determine si aplica consentimiento o excepción del art. 14 y documente sustento. 3. Vincule registros muestreados a versión de aviso y consentimiento cuando corresponda. 4. Pruebe en réplica entradas válidas, vacías y médico no autorizado, verificando servidor. 5. Acuerde antes PDF y límite 5 MiB para réplica; pruebe PDF válido, extensión prohibida, MIME discordante, vacío, 5 MiB y 5 MiB más un byte, todos inertes. 6. Compruebe rechazo, acceso restringido y almacenamiento sin ejecución del CV. 7. Registre diferencias con política productiva.

Evidencia a obtener. Avisos/base legal, matriz de hasta 50 registros disociados, reglas acordadas y resultados de seis archivos inertes; sin CV reales.

Excepción definida. Registro sin información o base legal; cuando corresponda consentimiento, ausencia de constancia previa, informada e inequívoca y escrita para datos sensibles; aceptación de médico no permitido o archivo fuera de tipo/tamaño; CV público sin autorización. La casilla aislada no acredita cumplimiento.

Horas. 5

Total: 28 horas, posteriores al reconocimiento. Muestras dirigidas, sin extrapolación estadística; documentar cualquier ajuste antes de ejecutar.

7. Anexo A Matriz de riesgos

N.º: R1 **Riesgo:** Divulgación cruzada **Causa con evidencia:** Patrón de orden E4; sesión débil E8; incidente según solicitud **Impacto:** Confidencialidad clínica y daño al paciente **Nivel:** Alto **Control existente observado:** Formulario DNI/clave, operación no probada **Control esperado:** Autorización por objeto, caché aislada y trazabilidad; P-01/P-03

N.º: R2 **Riesgo:** Suplantación **Causa con evidencia:** Clave inicial predecible y cuenta de pruebas E4 **Impacto:** Acceso ilegítimo a salud **Nivel:** Alto **Control existente observado:** Campo de contraseña, política no verificada **Control esperado:** Activación segura y cuentas de prueba restringidas; P-02

N.º: R3 **Riesgo:** Exposición en captura/tratamiento **Causa con evidencia:** GET/HTTP E6; HSTS ausente E8; aceptación sin texto según solicitud **Impacto:** Datos en URLs y tratamiento sin sustento **Nivel:** Alto **Control existente observado:** Casilla y formularios POST parciales **Control esperado:** TLS, cuerpo de petición, base legal y controles de CV; P-04/P-06

N.º: R4 **Riesgo:** Compromiso por dependencias/configuración **Causa con evidencia:** Huellas antiguas E2/E5 y rutas reveladas E3 **Impacto:** Alteración e indisponibilidad **Nivel:** Alto **Control existente observado:** Versiones visibles, sin prueba de parcheo **Control esperado:** Inventario, CVE y endurecimiento; P-05

N.º: R5 **Riesgo:** Exposición masiva **Causa con evidencia:** Activos omitidos/copia productiva E1 y respaldos/panel E7 **Impacto:** Divulgación a gran escala **Nivel:** Alto **Control existente observado:** Aviso visual de pruebas, sin barrera observada **Control esperado:** Segregación, anonimización, respaldos fuera de web y panel restringido; P-05

Fuentes y cierre de evidencia

F1 PHP, ramas sin soporte: https://www.php.net/eol.php

F2 Nginx, versiones heredadas: https://nginx.org/en/download.html

F3 Nginx, estable 1.22 del 24/05/2022: https://nginx.org/2022.html

F4 NIST NVD, CVE-2020-25213: https://nvd.nist.gov/vuln/detail/CVE-2020-25213

F5 Ley 29733, Congreso: https://www.leyes.congreso.gob.pe/documentos/leyes/29733.pdf

F6 WSTG 4.2: https://owasp.org/www-project-web-security-testing-guide/v42/

F7 ASVS 4.0.3: https://github.com/OWASP/ASVS/tree/v4.0.3/4.0/en

F8 ISO/IEC 27001:2022: https://www.iso.org/standard/27001 . Los controles se usan como correspondencia de planificación; cotejar el ejemplar institucional de NTP-ISO/IEC 27001:2022 antes de ejecutar. No se afirma certificación ni cumplimiento integral.

Reconocimiento del 28/10/2026. El manifiesto evidencias/SHA256SUMS.txt sella todos los TXT de evidencia excepto el propio manifiesto. Los hallazgos observados se distinguen de pruebas futuras. La alumna debe revisar el plan antes de entregarlo.